



數據感知與安全治理： 打造企業級 AI 智能工作流

慧與科技 (HPE)
數位科技服務事業處

張耀文 (Joy) 首席架構師

AI 投資報酬率的悖論：投入增加，卻得不到明顯產出

Why Two-Thirds of Enterprises¹ have been unable to move AI Pilots to Production

1. REGULATORY TSUNAMI

2025-26

- Geo-specific: Growing AI and Data regulations, fines
- Industry-specific: HIPAA AI addendum, PCI-DSS AI controls

2. ECONOMIC PRESSURE

CIO/CFO Scrutiny

- AI ROI under scrutiny, need to align spend with strategic value
- Can't allocate & manage costs without usage visibility

3. SECURITY MATURITY

CISO Evolution

- Prompt injection, jailbreak, exfiltration are mainstream
- Infrastructure security ≠ AI-specific threat defense



No controls, audit trail =
No production approval



No ROI tracking =
No budget expansion



No threat prevention =
No CISO sign-off

50%

Government will enforce AI regulations in 2026²

69%

Companies lack systems to track AI usage, compliance⁴

99%

Enterprises saw an attack on their AI services in 2025³

1. [McKinsey 66% of orgs haven't moved from AI pilots to production](#)
2. [Gartner: 50% of governments will enforce AI regulations in 2026](#)
3. [Palo Alto: 99% of orgs saw an attack on their AI services in 2025](#)
4. [Cato Networks: 69% of Enterprises in survey said they lack system to track AI usage and compliance](#)
5. [IBM: 13% of organizations reported AI system breaches, and most had no AI access controls.](#)

傳統 IT 資安 與 AI 資安

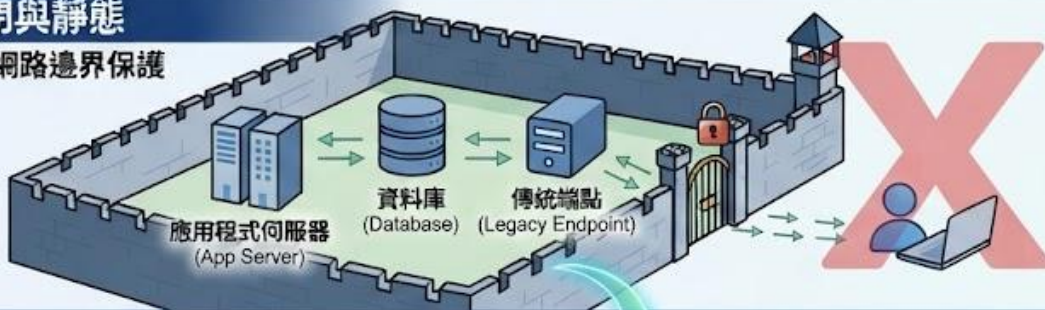
When Risk Moves from System **Boundaries** to **Runtime** Decisions

傳統 IT 資安 vs. AI 資安：結構性差異



防禦邊界：封閉與靜態

核心焦點：實體與網路邊界保護



特徵

- 防禦邊界 (Perimeter)
- 靜態規則 (Static Rules)
- 存取控制 (Access Control)
- 資料庫層級保護 (Database-level Protection)

防禦邊界：開放與動態

核心焦點：動態決策與推理保護



特徵

- 動態決策保護 (Dynamic Decision Protection)
- 即時推理監控 (Real-time Reasoning Monitor)
- 資料流動性 (Data Liquidity)
- 內部邏輯保護 (Internal Logic Protection)

結論
風險重心轉移：從靜態邊界到動態互動

Traditional Enterprise IT

- System logic is fixed
- Output determined by coded rules
- IAM / DLP / SIEM protect boundaries
- Risk trigger: unauthorized entry

RAG AI

- Prompt defines intent
- Retrieval selects semantic context
- Model synthesizes temporary knowledge
- Risk trigger: unintended context assembly

Agentic AI Systems

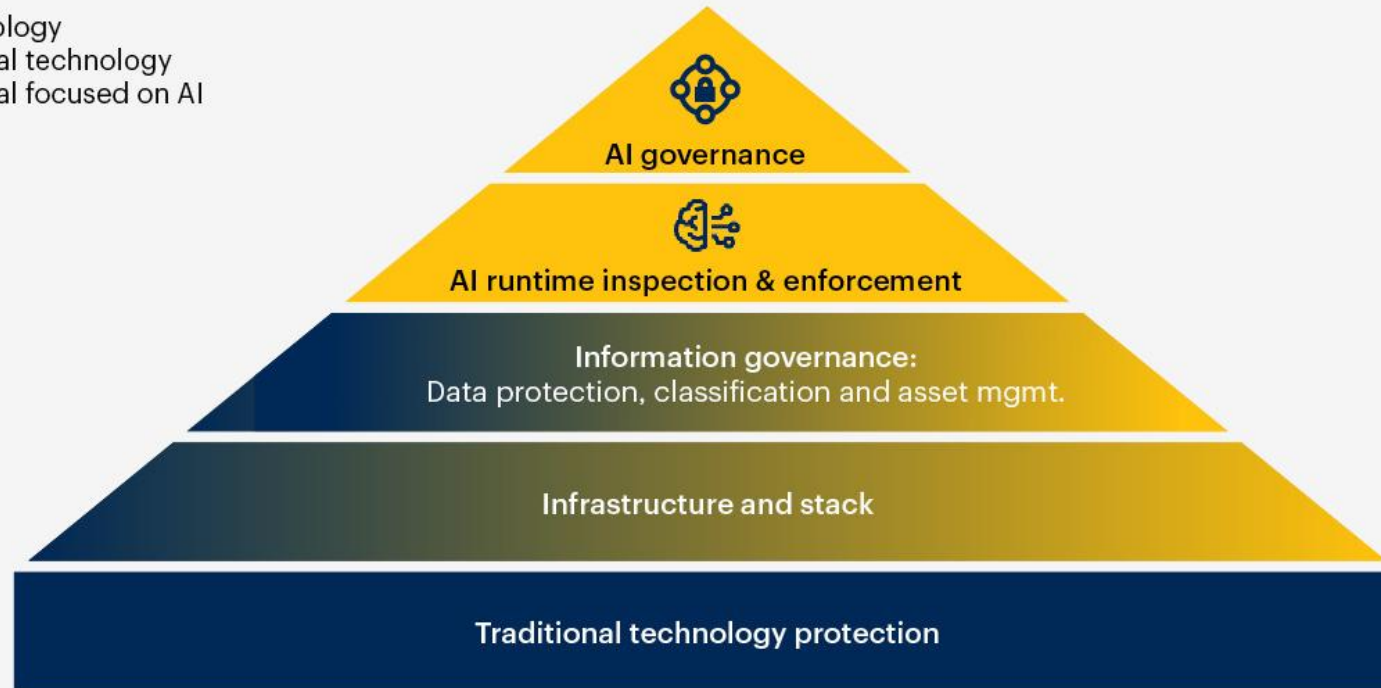
- Model selects tools
- Tool triggers workflow
- Output becomes action
- Risk trigger: valid step, invalid chain outcome

Gartner AI TRiSM (AI Trust, Risk and Security Management)

A framework to govern Enterprise AI risk, enforce trust, and scale adoption

AI TRiSM Technology Functions

- AI technology
- Traditional technology
- Traditional focused on AI



Source: Gartner
© 2024 Gartner, Inc. and/or its affiliates.
All rights reserved. CTMKT_3315851

Gartner®

AI TRiSM ensures AI governance, trustworthiness, fairness, reliability, robustness, efficacy and data protection.

AI TRiSM includes solutions and techniques for *model and application transparency*, *content anomaly detection*, *AI data protection*, *model and application monitoring and operations*, *adversarial attack resistance* and *AI application security*.

Gartner AI TRiSM (AI Trust, Risk and Security Management)

The Four Pillars of AI Governance

- **Explainability & Monitoring**
Action: Eliminate "Black Box" risks by ensuring AI decisions are auditable and understandable.
- **ModelOps (Operational Excellence)**
Action: Standardize the AI lifecycle from development to deployment.
- **AI Application Security**
Action: Defend against specialized threats (e.g., Prompt Injection).
- **Privacy & Data Protection**
Action: Deploy Privacy-Enhancing Technologies (PETs) and Synthetic Data.

Strategic Execution Roadmap

- **Asset Rationalization Phase**
Comprehensive AI Inventory: Establish an exhaustive catalog of all AI assets, including third-party plugins, open-source models, and proprietary in-house developments.
- **Governance Orchestration**
Cross-Functional AI Committee: Formalize a governance body comprising the CIO, CISO, and Legal Counsel to synchronize AI initiatives with corporate risk appetite.
- **Tiered Risk Management**
Contextual Classification: Implement differentiated TRiSM validation standards based on use-case risk levels (e.g., Internal Administrative tools vs. High-stakes Customer Credit Scoring).
- **Systematic Automation**
Implement 'Shift-Left' data validation and continuous runtime inspection to preemptively mitigate risks, scaling AI trust without manual friction

2025 OWASP Top 10 List for LLM and Gen AI

LLM01:25

Prompt Injection

This manipulates a large language model (LLM) through crafty inputs, causing unintended actions by the LLM. Direct injections overwrite system prompts, while indirect ones manipulate inputs from external sources.

LLM02:25

Sensitive Information Disclosure

Sensitive info in LLMs includes PII, financial, health, business, security, and legal data. Proprietary models face risks with unique training methods and source code, critical in closed or foundation models.

LLM03:25

Supply Chain

LLM supply chains face risks in training data, models, and platforms, causing bias, breaches, or failures. Unlike traditional software, ML risks include third-party pre-trained models and data vulnerabilities.

LLM04:25

Data and Model Poisoning

Data poisoning manipulates pre-training, fine-tuning, or embedding data, causing vulnerabilities, biases, or backdoors. Risks include degraded performance, harmful outputs, toxic content, and compromised downstream systems.

LLM05:25

Improper Output Handling

Improper Output Handling involves inadequate validation of LLM outputs before downstream use. Exploits include XSS, CSRF, SSRF, privilege escalation, or remote code execution, which differs from Overreliance.

LLM06:25

Excessive Agency

LLM systems gain agency via extensions, tools, or plugins to act on prompts. Agents dynamically choose extensions and make repeated LLM calls, using prior outputs to guide subsequent actions for dynamic task execution.

LLM07:25

System Prompt Leakage

System prompt leakage occurs when sensitive info in LLM prompts is unintentionally exposed, enabling attackers to exploit secrets. These prompts guide model behavior but can unintentionally reveal critical data.

LLM08:25

Vector and Embedding Weaknesses

Vectors and embeddings vulnerabilities in RAG with LLMs allow exploits via weak generation, storage, or retrieval. These can inject harmful content, manipulate outputs, or expose sensitive data, posing significant security risks.

LLM09:25

Misinformation

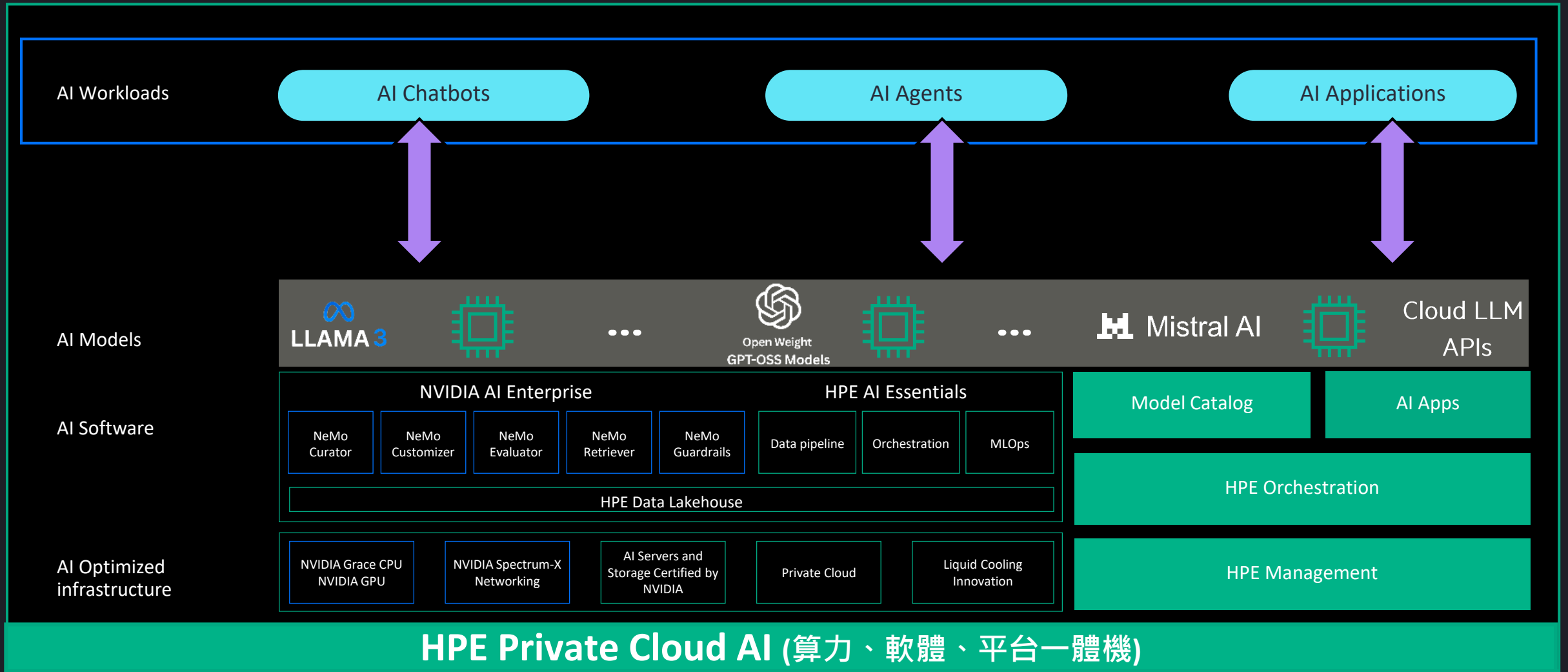
LLM misinformation occurs when false but credible outputs mislead users, risking security breaches, reputational harm, and legal liability, making it a critical vulnerability for reliant applications.

LLM10:25

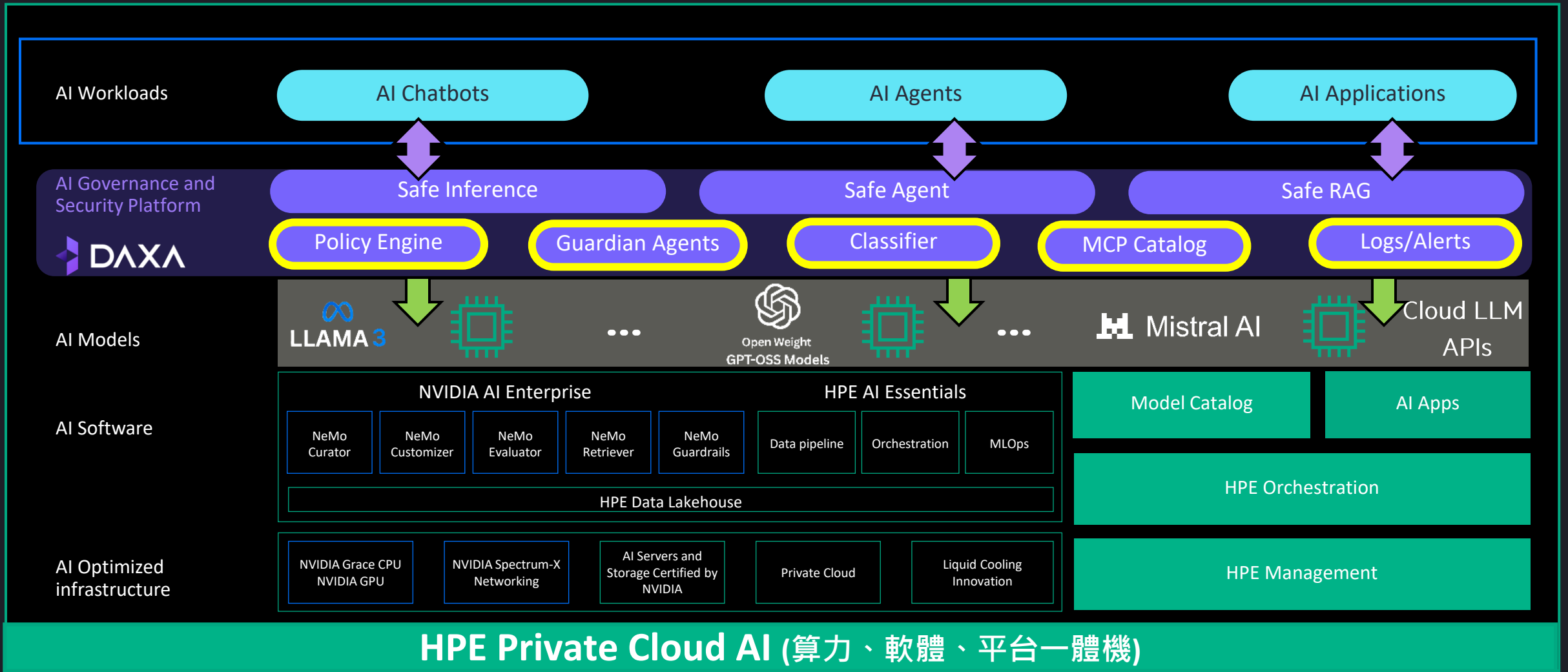
Unbounded Consumption

Unbounded Consumption occurs when LLMs generate outputs from inputs, relying on inference to apply learned patterns and knowledge for relevant responses or predictions, making it a key function of LLMs.

HPE PRIVATE CLOUD AI WITH DAXA GOVERNANCE, SECURITY



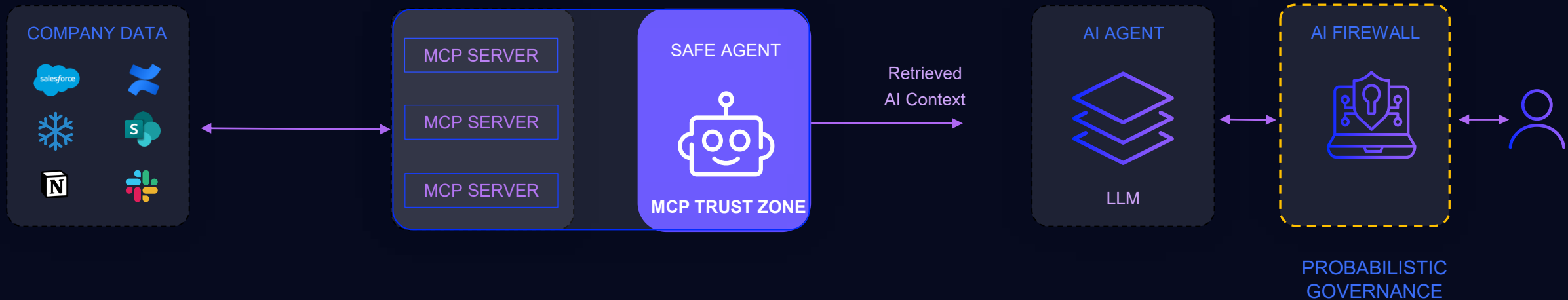
HPE PRIVATE CLOUD AI WITH DAXA GOVERNANCE, SECURITY



AI Firewalls Fail To Protect **When Agents Access Real Data**

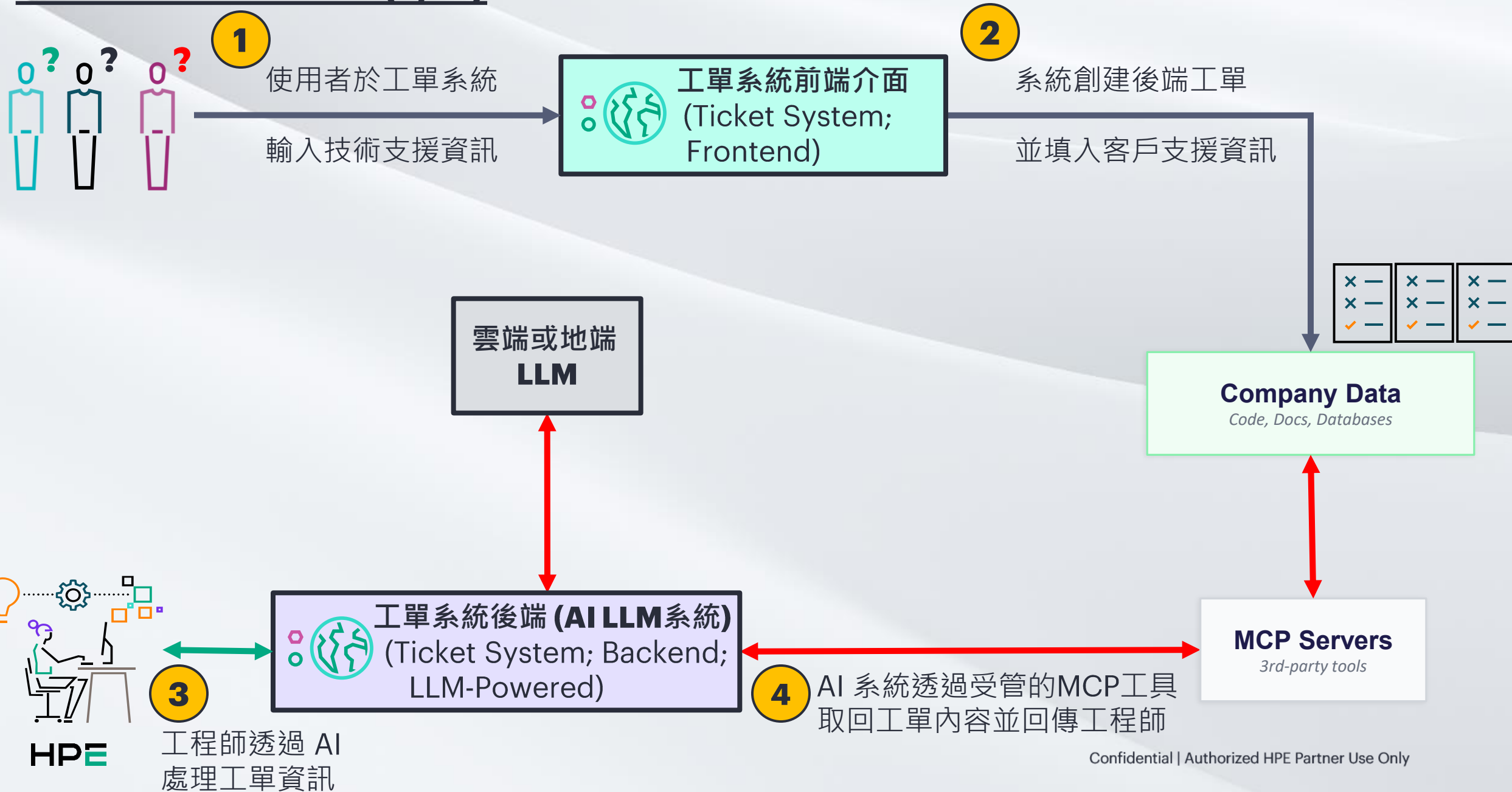


Probabilistic Approaches leads to AI Security & Governance by Guesswork



Shift-Left Approach: From controlling LLM output to controlling LLM input context

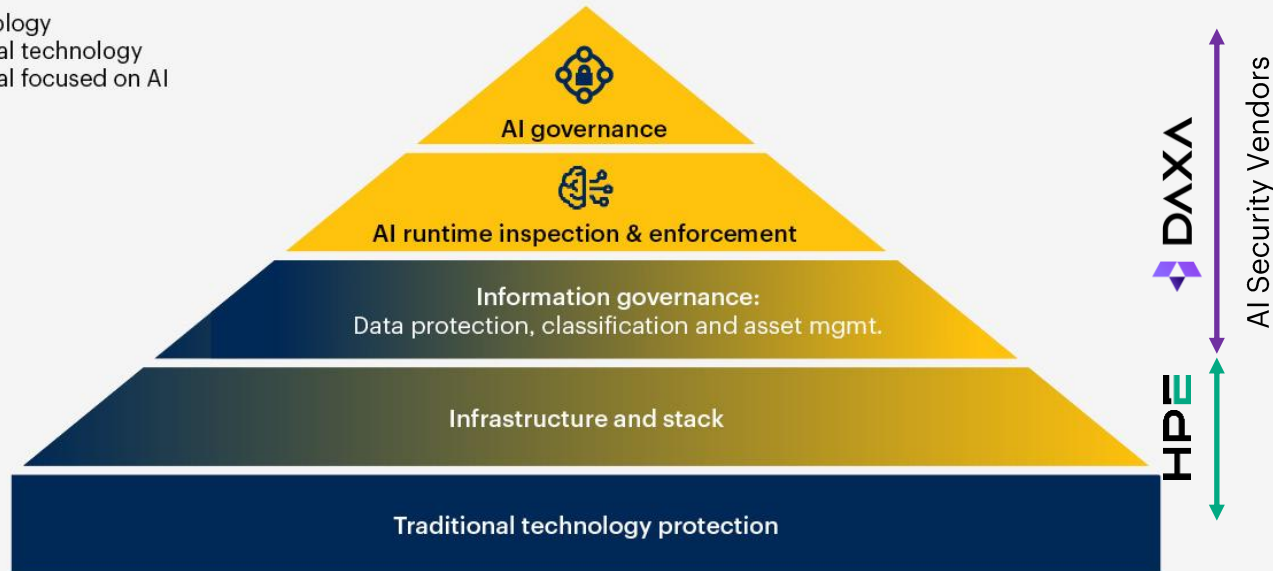
DEMO 情境說明 (1/4)



DAXA.AI : Built-In Protection in HPE AI Factory Ecosystem

AI TRiSM Technology Functions

- AI technology
- Traditional technology
- Traditional focused on AI



Source: Gartner
© 2024 Gartner, Inc. and/or its affiliates.
All rights reserved. CTMKT_3315851

Gartner



Totally agree with DAXA's approach of data-aware guardian agents. Information protection is a key function for agent security

Avivah Litan
AI TRiSM Leader, Gartner

From Pilot to Production. Across Every Industry.



**Trusted
where the
stakes are
highest.**

AI without data
governance isn't AI.
It's a liability.

GOVERNMENT & TELECOM	FINANCIAL & HEALTHCARE	ENTERPRISE & DATA	TECHNOLOGY & DEVELOPER
 U.S. Department of Veterans Affairs			
 United States Nuclear Regulatory Commission			 POSTMAN
			

Securing the Future – Protect AI solution from Novel threat landscape

Security risks and controls





Thank You